

Human identity: Identity Center, federation, MFA and Directory Service

Where people come from, how they prove it, and why an IAM user should be your last resort.

An IAM user is a **long-lived credential with a person attached**. AWS wants neither of those things.

IAM Identity Center

- ◆ One place to manage **who exists** and **which accounts they can reach**, across an entire organisation.
- ◆ Users sign in to an **access portal**, choose an account and a role, and receive **temporary credentials**. No access keys anywhere.
- ◆ **Assign to groups, not users**. Group-level assignment is what makes this scale past a handful of accounts.
- ◆ Supports a **delegated administrator**, so it is run from a security account rather than the management account.
- ◆ It is **Regional** – the instance lives in one Region, and that choice is not easily reversed.

ON THE EXAM

The old name was AWS SSO. Anything using that name means this service.

Permission sets

- ◆ A permission set plus an account assignment provisions a real **IAM role in the target account**, named **AWSReservedSSO_** and a hash.
- ◆ So everything from module 19 still applies. SCPs, RCPs and boundaries all cap it exactly as they would any other role.
- ◆ A permission set can contain AWS managed policies, an inline policy, **customer managed policy references**, and a **permissions boundary**.
- ◆ **Session duration** is set on the permission set, from 1 to 12 hours.
- ◆ **Deleting a permission set removes the backing role from every account** it was provisioned to.

ON THE EXAM

A permission set is a template. The thing that actually gets evaluated is an ordinary IAM role, in the account, with an ugly name.

Identity sources, and the MFA nuance

- ◆ Three sources: the built-in **Identity Center directory**, **Active Directory**, or an **external identity provider**.
- ◆ External connects by **SAML 2.0** for authentication and **SCIM** for provisioning.
- ◆ **Identity Center's own MFA applies only with its directory, Managed Microsoft AD, or AD Connector.**
- ◆ With an **external SAML provider**, authentication is delegated – MFA is enforced there.
- ◆ Whoever authenticates the user is who enforces the second factor.

ON THE EXAM

Enabling Identity Center MFA while federating externally changes nothing.

SAML federation straight into IAM

- ◆ The older path: a **SAML identity provider** object in IAM, and roles trusting it.
- ◆ The assertion carries a **Role attribute** with the role and provider ARNs, plus a **RoleSessionName**.
- ◆ **RoleSessionName** appears in **CloudTrail** and is not immutable.
- ◆ **Sourcidentity** is stronger – once set it **cannot be changed**, and it survives role chaining.
- ◆ Still valid. Identity Center is the recommendation for new multi-account deployments.

ON THE EXAM

A tamper-resistant record of which human acted is **Sourcidentity**, not **RoleSessionName**.

MFA methods

METHOD	NOTES
FIDO2 security key	Phishing-resistant. AWS's recommendation
Passkey	FIDO2 in a device or password manager. Also phishing-resistant
Virtual TOTP app	Widely used, and phishable – the code can be relayed
Hardware TOTP token	For environments that forbid phones

ON THE EXAM

Up to eight MFA devices per root user and per IAM user. Register more than one, or a lost phone becomes an incident.

Root MFA is now enforced

- ◆ **May 2024:** MFA required for AWS Organizations **management account** root users.
- ◆ **June 2024:** extended to **standalone account** root users.
- ◆ **November 2024:** centralised root access management for Organizations arrives. Module 34.
- ◆ **17 June 2025: MFA enforced for root users across all account types**, including member accounts.
- ◆ So 'enable MFA on the root user' is no longer a recommendation you might act on. It is enforced, and root sign-in without it is blocked.

ON THE EXAM

Dated: material written before mid-2025 describes root MFA as a best practice. It is now a requirement across every account type.

Managed Microsoft AD, or AD Connector?

MANAGED MICROSOFT AD

A real directory in AWS

- Actual Active Directory, managed by AWS
- Can trust your on-premises forest
- Works if the link to on-premises is down
- Supports AD-aware workloads in AWS

AD CONNECTOR

A proxy to yours

- Stores no identities in AWS at all
- Redirects authentication on-premises
- Needs the link up to authenticate anyone
- Cheapest way to reuse existing identities

THE TIEBREAKER

'No identities may be stored in AWS' is the phrase that picks AD Connector. 'Must keep working if the link drops' picks Managed Microsoft AD.

A company uses IAM Identity Center with an external SAML identity provider as its identity source, and SCIM for provisioning. A compliance requirement says all AWS console access must use MFA.

The security team enables MFA in the IAM Identity Center settings and sets it to 'always-on'. An audit two months later finds users signing in to the access portal and reaching accounts without ever presenting a second factor.

Why, and what should the team do?

- | | |
|---|---|
| <p>A Identity Center MFA does not apply when the source is an external IdP; enforce MFA at the identity provider</p> | <p>B MFA must also be enabled on each permission set; add it there</p> |
| <p>C SCIM provisioning overwrites the MFA setting; switch to manual provisioning</p> | <p>D The Identity Center instance is in the wrong Region; recreate it in the users' Region</p> |

◆ PAUSE AND DECIDE

Why, and what should the team do?

- A

 External IdP means MFA is enforced there, not in Identity Center
Correct. Identity Center MFA applies only with its own directory, Managed Microsoft AD or AD Connector. With SAML, authentication is delegated entirely.
- B

 Enable MFA on each permission set
Permission sets define permissions and session duration. They have no MFA setting – authentication happens before a permission set is involved.
- C

 SCIM overwrites the setting
SCIM synchronises users and groups. It does not touch instance-level authentication settings, and manual provisioning would change nothing.
- D

 Wrong Region
The instance's Region affects where it runs, not whether MFA is challenged. Users were signing in successfully, so the instance is reachable.

THE SIGNAL

The setting was enabled and had no traffic to act on. Whoever authenticates the user is who enforces the second factor.

A media company assigns one Developer permission set to 60 accounts. Developers must be able to manage EC2 instances tagged with their own team name, and no others. There are 14 teams.

The current approach is 14 permission sets, one per team, each with a hardcoded tag condition. Maintaining them across 60 accounts has become the platform team's largest recurring task.

What should the company implement?

- ☐ A One permission set per account, scoped to the teams present in that account
- ☐ B A permissions boundary on each permission set listing the allowed tag values
- ☐ C Attribute-based access control: pass the team attribute from the IdP and match `aws:PrincipalTag` in one permission set
- ☐ D An SCP per OU denying `ec2` actions on instances not tagged for that team

◆ PAUSE AND DECIDE

What should the company implement?

- A

 One permission set per account
Turns 14 permission sets into 60 or more. It multiplies the maintenance problem the scenario is asking you to remove.
- B

 A permissions boundary per permission set
A boundary caps rather than distinguishes. You would still need a different boundary per team, which is the same 14 artefacts renamed.
- C

 ABAC with the team attribute and `aws:PrincipalTag`
Correct. One permission set whose condition compares the caller's team tag against the resource tag - the attribute changes per user, the policy never does.
- D

 An SCP per OU
SCPs cap and never grant, so this cannot give developers access. It also puts a per-team rule in an org-level control, which is the wrong altitude.

THE SIGNAL

Fourteen near-identical artefacts is the tell. ABAC replaces them with one policy and an attribute that varies.

A defence contractor must let staff use their existing on-premises Active Directory identities to access AWS. A security policy states that no user credentials or password hashes may be stored in AWS under any circumstances.

The site has a redundant Direct Connect link to the data centre. Staff access AWS only from the corporate network during working hours.

What should the contractor use?

- ☐ A AWS Managed Microsoft AD with a two-way trust to the on-premises forest
- ☐ B AD Connector as the Identity Center identity source
- ☐ C Simple AD, synchronised nightly from the on-premises directory
- ☐ D IAM users created to mirror the Active Directory accounts

◆ PAUSE AND DECIDE

What should the contractor use?

- A

 Managed Microsoft AD with a forest trust
A directory running in AWS. A trust avoids duplicating accounts, and the scenario's absolute wording about storing nothing in AWS makes AD Connector the safer read.
- C

 Simple AD synchronised nightly
Simple AD is a standalone directory, so synchronising means copying accounts into AWS – exactly what the policy forbids. It also supports no trust.
- B

 AD Connector
Correct. It stores no identities in AWS at all – it proxies authentication to the on-premises directory. The redundant Direct Connect answers its one weakness.
- D

 Mirror them as IAM users
Duplicates every identity into AWS with its own credentials, which breaks the policy and creates the long-lived credentials this module opened by arguing against.

THE SIGNAL

AD Connector's weakness is dependence on the link. The scenario hands you a redundant Direct Connect, which is not decoration.

An insurer federates SAML directly into IAM. During an incident investigation, CloudTrail shows actions taken by an assumed-role session, and the session name is a value the identity provider was configured to send.

Auditors want assurance that the recorded identity is one the user could not have influenced, and that it remains attached if that session assumes a further role.

What should the insurer configure?

- ☐ A A stricter RoleSessionName format enforced by the identity provider
- ☐ B Session tags passed with sts:TagSession, marked transitive
- ☐ C CloudTrail data events on the STS API to capture full assertion contents
- ☐ D sts:SourceIdentity, set from a SAML attribute and permitted in the trust policy

◆ PAUSE AND DECIDE

What should the insurer configure?

A A stricter RoleSessionName format

Improves consistency, not assurance. RoleSessionName is not immutable, and a stricter format does not make it tamper-resistant.

C CloudTrail data events on STS

STS calls are management events, and CloudTrail records the call rather than assertion contents - the module 18 lesson in a different service.

B Transitive session tags

Half right - transitive tags do survive chaining. But tags carry attributes rather than an immutable identity, and they can be set differently on a later hop.

D sts:Sourceldentity from a SAML attribute

Correct. Once set it cannot be changed for the life of the session, and it persists through role chaining - exactly the two properties the auditors asked for.

THE SIGNAL

Two requirements: cannot be influenced, and survives chaining. Sourceldentity is the only attribute with both properties.

Five things to carry forward

- ◆ **A permission set provisions a real IAM role.** SCPs, RCPs and boundaries cap it like any other.
- ◆ **Identity Center MFA applies only to its own directory, Managed Microsoft AD or AD Connector.** An external IdP enforces its own.
- ◆ **Root MFA has been enforced across all account types since 17 June 2025.** It is not a recommendation any more.
- ◆ **AD Connector stores nothing in AWS.** Managed Microsoft AD keeps working when the link drops.
- ◆ **Sourceldentity is immutable and survives chaining.** RoleSessionName is neither.

ON THE EXAM

Next: application identity – Cognito user pools and identity pools, presigned URLs and Verified Permissions.